1. 情報セキュリティ環境

1-1. 職業倫理の理解、遵守、推進

- 多くの組織では、価値観やステークホルダーに対する義務を明記した倫理規約を作成する

職業倫理

- 社会に貢献するために、職業上のガイドラインやベストプラクティスに沿って、全体の利益を考えて行動すること

ISC2 倫理規約

- ISC2 メンバーが信頼を得るために、正しいマナーに従い、専門家としてふさわしい振る舞いをし、利益をもたらす存在とみなされること
- ISC2 倫理規定の規律：
    - 社会、一般大衆の福利、およびインフラを保護する
    - 公正かつ誠実に責任をもって合法的に行動する
    - 当事者に対して、十分かつ適切なサービスを提供する
    - 専門知識を高め、維持する (維持にはCISSPの試験内容を公にしないことが含まれる)
    - 違反した場合は、委員会による認証が取り消される可能性がある

組織の倫理規約

- 許容される行動様式を規定するもの

エンロン事件とSOX法の策定

- SOXは、企業に対して財務報告の透明性と会計処理の文書化を求める米国の法律
- 1990年代末から2000年代初めにかけて、エンロンなどの一流上場企業が関わる会計疑惑が連続したため、その対策としてSOX法が策定された

SOC (System and Organization Controls) レポート

- SOCは、SOX法のコンプライアンス要件に対応するための認証された報告書
- SOC監査では、他の監査（一般監査、データ保護監査、財務監査など）が適切に実施されているかを検証する

1-2. セキュリティ概念の理解と適用

- 情報は、意思決定に利用されるものほど価値を持つ
- 情報セキュリティは、情報が正しく、完全であり、意思決定をサポートするために利用可能であることを確認すること

機密性、完全性、可用性

- 情報セキュリティの基本的な目標は、機密性、完全性、可用性 (CIAの三要素) を維持すること（Confidentiality, Integrity, Availability）
    - 機密性（Confidentiality）：アクセス権が保たれていること

    - 完全性（Integrity）: 改竄されていないこと
    - 可用性（Availability）: 必要な時に利用できること

真正性、否認防止、プライバシー、安全性

- CIA以外のモデルは、セキュリティに関心を持ち続けるためのものとして使われる
    - 真正性 : データが信用できるかを確認できること
    - 否認防止 : 過去の行為を取り消すことができないこと
    - プライバシー : 個人の活動に対する利益が他人に強制的に奪われないこと
        - OECDはプライバシーガイドラインを1980年に発表し (2013年に改定)、多くの国ではこのプライバシー基本8原則に基づいた法律を策定している
            - 収集制限の原則：個人データは適法かつ公正な手段で、可能な場合は本人の知識または同意を得て収集すること。
            - データ品質の原則：個人データは利用目的に沿ったものであり、必要な範囲で正確、完全かつ最新の状態に保つこと。
            - 目的明確化の原則：データの収集目的を遅くとも収集時までに特定し、利用はその目的達成の範囲に限定すること。
            - 利用制限の原則：本人の同意がある場合や法律の規定による場合を除き、特定された目的以外にデータを利用・開示しないこと。
            - 安全保護の原則：紛失、破壊、不正なアクセス、改ざん、開示などのリスクから合理的な安全保護措置によって個人データを守ること。
            - 公開の原則：個人データの保護に関する方針、慣例、実施体制等を一般に公開すること。
            - 個人参加の原則：本人が自己のデータの保有を確認する権利、データ提供を求める権利、不正確なデータの修正・削除を求める権利を持つこと。
            - 責任の原則：データ管理者は、上記原則を実施するための措置を遵守する責任（説明責任）を負うこと。
        - PII (Personally Identifiable Information) は、個人を特定できる情報
        - PHI (Protected Health Information) は、個人のプライバシーに関する保健情報
        - 米国の法律であるHIPPAプライバシールールでPHIの扱いが書かれている
    - 安全性 : 人や財産への危害を防止・制御すること

デューケアとデューデリジェンス

- 権限や責任を持つ人が遵守し、実行しなければならない義務
    - デューケア : 組織や顧客に対して負う義務。役割。妥当な注意。常識人として一般的に期待される行動（把握したリスクに対策を講じる・行動する）
    - デューデリジェンス : 実施した作業の裏付け。説明責任。適切な注意。責任を果たすためにすべき努力（事前にリスクを調べる・把握する）

1-3. セキュリティガバナンス原則の評価と適用

- リスク低減のためにポリシーの作成やトレーニングを実施し、必要な行動がとられるように管理すること
- プロセスの信頼性と再現性を高めることで、効率性・安全性・セキュリティを得ることができる

セキュリティ機能のビジネス戦略、目標、使命、目的との連携

- ビジネスなしにセキュリティ部門は存在できない
- アライメント（整合性）は、目標や目的を達成するために計画やリソースを調整すること

- ビジネス影響度分析 (BIA) は目標、リソース、リスクの整合性を把握するための手段

組織のガバナンスプロセス

- ガバナンスは、組織を運営するためのプロセスであり、現場を観察して目標に向かっていないものを修正すること
- ガバナンス委員会は、一部の企業で使われて、組織内の意思決定方法を決定する
- セキュリティの目標は、ビジネス目標をサポートすること
- 買収、合併、子会社化は、セキュリティに影響を与える可能性がある

組織の役割と責任

- セキュリティ機能は、組織の階層構造に依存する
- セキュリティ関連の役割：
    - 経営陣 : 組織の上層部でポリシーを指示したり、組織に義務を課す権限を持つ役員や幹部
    - セキュリティマネージャー/オフィサー/ディレクター : 組織内の上級セキュリティ担当者
    - 構成管理ボード（CCB）：ITシステムやソフトウェアの構成要素（サーバー、アプリケーション、設定ファイルなどの構成アイテム：CI）の変更内容を審議し、承認または却下するための会議体、あるいはその管理プロセス
    - セキュリティ担当者 : 組織内のセキュリティ専門家。管理者、アナリスト、インシデントレスポンダーなど
    - ユーザー : 従業員。システムの安全な操作やセキュリティガイダンスの同意書への署名、潜在的なインシデントを報告できるようにトレーニングなどが必要

セキュリティコントロールフレームワーク

- 以下のガバナンスプログラムを提供
    - 首尾一貫した
    - 測定可能な
    - 標準化された
    - 包括的な
    - モジュラーな
- ISO/IEC27000シリーズ
    - 国際標準化機構（ISO）と国際電気標準会議（IEC）が共同で発行した情報セキュリティ管理のベストプラクティス
        - ISO/IEC27000、ISO/IEC27001
            - 用語の定義
        - ISO/IEC27002
            - セキュリティコンとrーるのカタログ
        - ISO/IEC27003
            - ISMS（セキュリティ管理の仕組み）実装ガイダンス
        - ISO/IEC27005
            - リスク管理

COBIT（Control Objectives for Information and Related Technology）

- アメリカの情報システムコントロール協会（ISACA）が策定した、企業や組織の「ITガバナンス」と「ITマネジメント」を最適化するための国際的なベストプラクティス・フレームワーク

米国国立標準技術研究所（NIST）および連邦情報処理標準（FIPS）

- NIST（米国国立標準技術研究所）
    - 米国商務省に属する科学技術系の政府機関
    - 測定基準や科学技術の標準化を担い、情報セキュリティやサイバーセキュリティ分野においては「NISTサイバーセキュリティフレームワーク (CSF)」や「SP800シリーズ」など、世界的にも広く参照される基準やガイドラインを数多く発行する
- FIPS（連邦情報処理標準）
    - NISTが発行する、コンピュータや情報処理システムに関する統一規格の総称です（Federal Information Processing Standards）
- セキュリティの分類と基準（コア規格）
    - FIPS 199（情報システムのセキュリティ分類基準）:情報システムが扱う情報の重要性を、CIA（機密性・完全性・可用性）の3つの観点から評価し、組織への影響度を「低（Low）・中（Moderate）・高（High）」の3段階に分類する基準です。
    - SP 800-60（セキュリティ分類のマッピングガイド）:FIPS 199を実務で使うための手引書です。政府の業務や情報のタイプ（人事、財務、医療など）を具体的な例に紐解き、どのように影響度（低・中・高）を割り当てるべきかを解説しています。
    - FIPS 200（最低限のセキュリティ要求事項）:FIPS 199で割り出した影響度（低・中・高）に応じて、情報システムが最低限満たさなければならないセキュリティ要求事項（17の分野）を定めた必須の基本規格です。
- 具体的な管理策の適用
    - SP 800-53（セキュリティとプライバシー管理策のカタログ）:FIPS 200が定める要求事項をクリアするための、具体的な対策（セキュリティコントロール）の膨大なメニュー集です。アクセス制御やインシデント対応など、詳細なセキュリティメニューがここから選択・適用されます。
- リスク管理の手法とライフサイクル
    - SP 800-39（組織全体のリスクマネジメント）:リスク管理を「組織レベル（経営）」「業務プロセスレベル」「情報システムレベル」の3つの階層（ティア）で包括的に捉え、管理・運営するための最上位のフレームワークです。
    - SP 800-37（リスクマネジメントフレームワーク：RMFの適用ガイド）:システムのライフサイクル全体を通じて、リスクをどう評価し、対策を選んで運用承認（認証）を得るかという具体的な「6〜7つのステップ（RMFの手順）」を定めた実務ガイドです。
    - SP 800-30（リスクアセスメントの実施手引）:SP 800-37や39のプロセス内で必要となる、「脅威の特定」「脆弱性の評価」「影響の分析」といったリスク評価（アセスメント）の具体的なやり方に特化した解説書です。
    - SP 800-64（システム開発ライフサイクル：SDLCにおけるセキュリティ）:システムの設計・開発段階から廃棄に至るまでの開発ライフサイクル（SDLC）の各フェーズに、どのようにセキュリティ（RMFの考え方）を組み込むかを定めたガイドラインです。

- 特殊なシステムへの適用
    - SP 800-59（国家安全保障システム：NSSの特定基準）:NISTの多くの基準が「非国家安全保障システム」を対象とするのに対し、扱っているシステムが「国家安全保障システム（NSS）」に該当するかどうかを識別・定義するための基準です（NSSに該当する場合は、さらに厳格な別の基準や国防総省のルールが適用されます）。

ペイメントカード業界データセキュリティ基準（PCIDSS）

- PCI DSS（Payment Card Industry Data Security Standard）は、クレジットカード会員データを安全に取り扱うことを目的として策定された国際的な情報セキュリティ基準です。

ペイメントアプリケーションデータセキュリティー基準（PA DSS）

- PA-DSS（Payment Application Data Security Standard）は、クレジットカードの決済アプリケーション向けの国際的なセキュリティ基準

PINセキュリティサービス（PCI PIN）

- クレジットカード等の個人識別番号（PIN／暗証番号）および関連する暗号鍵の安全な管理、処理、伝送を目的として、国際的な決済ブランド（Visa、Mastercard、JCB、American Express、Discover）が策定したセキュリティ基準

FedRAMP（Federal Risk and Authorization Management Program）

- FedRAMP（Federal Risk and Authorization Management Program：連邦リスクおよび承認管理プログラム）は、米国連邦政府がクラウドサービスを利用する際に、統一された基準でセキュリティ評価・認証・継続的監視を行うための政府横断プログラムです。
- 連邦政府機関がクラウドサービスを導入する際、各省庁が個別に実施していたセキュリティ審査の重複をなくし、「一度評価すれば、全庁で再利用可能（Assess once, use many times）」にすることを目指しています。
- クラウド事業者（CSP）は、認定された第三者評価機関（3PAO等）による厳格なセキュリティ評価を受け、JAB（統合認可ボード）による暫定運用権限（P-ATO）または各連邦政府機関からの運用権限（ATO）を取得します。

SABSA（Sherwood Applied Bussiness Security Architecture）

- SABSA（Sherwood Applied Business Security Architecture）は、ビジネス目標やリスク管理にセキュリティを直結させるために設計された、ビジネス駆動型（ビジネス起因）のエンタープライズ情報セキュリティアーキテクチャのフレームワークおよび方法論です。

ポリシー、スタンダード、ガイドライン、プロシージャ

- ポリシー：「戦略的」とか説明されている参考書が多いですが「こうありたい！」という理想論だとイメージしておけばOKです。
    - 具体例：当社ではお客様から預かるデータを安全に保護する
- スタンダード：これはポリシーという理想論を実現するために「*最低限これだけはやる！」という言わば理想を形にするための決まり事だとイメージしておけばOKです。
    - 具体例：お客様から預かるデータはAESによる暗号化の上、特定サーバのみに保管する

- プロシージャ：これはスタンダードで少し具体化されたやるべき施策を実装する方法だとイメージしてください。
    - 具体例：特定サーバにログインする＞管理コンソールのタブから「HDD」を選択＞暗号化のタブを選択し、暗号化種類をAESにする＞完了を選択する。←みたいな手順書だと考えてください！
- ガイドライン ：これは深入り不要です。ポリシー、スタンダード、プロシージャのどこにも書いてないことで困ったときにみるお助けブックとでも覚えておけばOKです！

1-4. 法的環境

- 法律、規制、スタンダード、契約は、すべて組織の行動に影響を与える

法的環境

- 法的要件を知ることは、コンプライアンス違反のリスクを低減し、組織が守るべきビジネス要件と法的要件を理解するのに役立つ

契約上の要件、法的要素、業界標準および規制要件

- 組織は、所属する業界や法律などの規制を遵守すること
- スタンダードは、伝統的・文化的な義務の一部をまとめたもの
- コンプライアンスは、規則を遵守すること
- コンプライアンスレビューを実行するために使用されるツール、プロセス、およびアクティビティは監査と呼ばれる

プライバシー保護

- プライバシーは、自分に関する情報が出回る方法と範囲を制限できる権利のこと
- 1980年に、OECDが初めて「OECDプライバシーガイドライン」を発表した (2013年に改定)
- OECDのプライバシー原則は国際的に合意された最初のプライバシー原則であり、世界中のプライバシー関連の法律や規制の基となっている
- 2018年には欧州連合で一般データ保護規則 (GDPR) が発表された

欧州連合

- eプライバシー指令
    - 欧州連合（EU）におけるデータ保護とプライバシーに関する一連の規則です。完全な正式名称は「Privacy and Electronic Communications Directive 2002/58/EC」です。これは、Cookieの使用、電子メールマーケティング、データの最小化、および データプライバシーのその他の側面を規制するものです。他のEU指令と同様に、それ自体は拘束力のある法律ではなく、EU加盟国に対して指令に沿った独自の法律を作成するように指示するものです。
    - eプライバシー指令は2002年に可決され、その後2009年に改正されました。この指令は近い将来、eプライバシー規則に置き換わることが予定されています。

一般データ保護規則（GDPR）

- データコントローラー（データ管理者）
- データプロセッサー（データ処理者）
- GDPR第5条：EU一般データ保護規則（GDPR）第5条は、個人データの取り扱いに関する6つの基本原則と、それを管理者に義務づける説明責任（アカウンタビリティ）を定めています。

    - 適法性、公正性及び透明性：適法、公正かつ透明性のある方法で処理すること。
    - 目的の限定：特定され明確な正当な目的のためにのみ収集し、目的外の処理をしないこと。
    - データの最小化：処理目的に照らして必要最小限に限定すること。
    - 正確性：正確かつ必要に応じて最新に保つこと。
    - 保存期間の制限：目的に必要な期間を超えて保持しないこと。
    - 完全性および機密性：適切なセキュリティ確保のもとで処理すること

国際データ移転-十分性認定

- CJEU（欧州司法裁判所）における国際データ移転とは、欧州経済領域（EEA）から域外の「第三国」へ個人データを移転する際、「EU域内と同等のデータ保護水準が移転先でも維持されなければならない」とする一連の厳格な法的判断や、それを巡る判例を指します。
- GDPR（第5章）では域外へのデータ移転を原則禁止しており、例外的に移転を認める仕組み（移転ツール）を定めています。CJEUはこの法的根拠の有効性について歴史的な判決を下し、世界のデータ保護実務に決定的な影響を与えてきました。

プライバシーシールド

- セーフハーバーやプライバシーシールドは、GDPRの発表と同時に米国ではEUの個人や組織との取引に関する概念として開発された
- プライバシーシールドは、米国とEUの合意により実施され、米国商務省がこれを監視している
    - プライバシーシールド（Privacy Shield）は、2016年に米国商務省と欧州委員会、スイス当局との間で締結された、EU市民個人情報の国外移転を可能にするためのプライバシー保護フレームワークです。
    - セーフハーバー（Safe Harbour）とは、「定められた一定の条件や基準を満たしていれば、法令違反やペナルティ（罰金・課徴金・課税など）の対象外とする」という免責規定やルールのことです。
- 2020年7月に、欧州連合司法裁判所はプライバシーシールド協定を破棄した
    - プライバシーシールドは米国の監視活動の影響を受けるためにEU市民を保護するものではないと主張する原告を支持したため
- プライバシーシールドの7原則：
    - 通知 (Notice)
    - 選択 (Choice)
    - 第三者移転に対する説明責任 (Accountability for Onward Transfer)
    - セキュリティ (Security)
    - データ完全性および目的外利用の禁止 (Data integrity and Purpose Limitation)
    - アクセス (Access)
    - 救済・執行・責任 (Recourse, Enforcement, and Liability)

忘れられる権利

- 忘れられる権利は、市民がデータオーナーなどに対して自分に関わる情報を削除するように要求する権利
- EUの法律や規制 (GDPR) で確立されている原則。EU以外の国でも導入されている

データポータビリティ

- データポータビリティ権は、データサブジェクトが、あるデータコントローラーが保有する自分に関するデータを、別のデータコントローラーに転送して利用できるように要求する権利
- システムの移行時にデータを移す際に行使される権利
- システムのデータは、他のシステムで容易に受け入れできるように構造化されていることが必要

データのローカリゼーション

- 国境を超える情報や国内のデータサブジェクトに適用される法律は、国ごとに異なる
- GDPRでは、プライバシーにかかわる情報をEU/EEA域外に持ち出し、GDPRの要求事項に準拠していない国のシステムに転送する際の条件を定めている

国と地域の例

- 米国：
    - 業界固有のプライバシーデータ保護法があるが、全米での統一的なプライバシーデータ保護法はない
    - 米国憲法修正第4条では、国民は政府による不当な捜索や押収から保護される。この解釈を拡張してプライバシーの侵害に対する保護も含めている
    - 米国パトリオット法は、9月11日の同時多発テロの直後、2001年10月26日に署名され、裁判所の捜査令状などがなくてもデータオーナーなどに対する捜索・押収の権限を拡大した
        - 米国パトリオット法（正式名称：米国愛国者法、USA PATRIOT Act）は、2001年9月11日の同時多発テロを受け、同年10月26日にジョージ・W・ブッシュ大統領が署名して成立した米国の包括的テロ対策法
        - 電子情報開示（eディスカバリ）
- アジア太平洋経済協力会議 (APEC)：
    - APECのプライバシーフレームワークでは、情報フローに対する障壁をなくし、持続的な貿易と経済成長を確保するためのプライバシー保護を定めている

米国の法律 [追加]

- 合衆国法律集 (USC; United States Code) : 米国のすべての連邦刑法と民法の条文が記載されている
- SOX : 上場企業会計改革および投資家保護法
- HIPPA (Health Insurance Portability and Accountability Act) : 医療保険の相互運用性と説明責任に関する法律
    - HIPPAの対象団体に代わって個人の健康情報を扱う者は、ビジネスアソシエイツ契約 (BAA) の条項に従うこと
- FERPA (Family Educational Rights and Privacy Act) : 学生の記録のプライバシーを保護する法律
- COPPA (Children's Online Privacy Protection Act) : 児童オンライン保護法
    - 13歳未満の子供から個人情報を収集するには、事前にWebサイトで保護者の同意を得ることを要求する
- GLBA (Gramm-Leach-Bliley Act) : グラム・リーチ・ブライリー法
    - 金融機関の顧客の機密データを保護する法律 (民法)
- FISMA : 米国連邦政府の情報セキュリティに関する規則
    - Federal Information Security Management Act : 連邦情報セキュリティマネジメント法（2002制定）
    - Federal Information Security Modernization Act : 連邦情報セキュリティ近代化法（2014年制定）
- HSA (Homeland Security Act) : 国土安全保障法
- CFAA (Computer Fraud and Abuse Act) : コンピュータ不正行為防止法
    - 悪意を持って任意の1年間に連邦政府コンピュータシステムに$5000を超える損害を与えると、連邦政府に対する犯罪となる
- CALEA (Communications Assistance for Law Enforcement Act) : 法執行機関のための通信援助法
    - すべての通信事業者に対して、裁判所の命令を受けている法執行機関当局者は、盗聴できることを要求する

- ECPA (Electronic Communications Privacy Act) : 電子通信プライバシー法
- eDiscovery (eディスカバリー, 電子情報開示) : 当事者は、事件に関連する全情報の開示を求めることができる制度

知的財産（IP）の保護

- IP（Intellectual Property）の保護とは、人間の知的活動によって生み出されたアイデアや創作物の価値を、法律に基づいて守ることです。ソフトウェア開発において、IPは企業の競争力の源泉そのものです。
- EULA（End-User License Agreement）は、ソフトウェアの「開発者（権利者）」と「購入・利用するユーザー」との間で結ばれる法的契約です。
- 有効期限 : 特許は20年。著作権は作者の死後70年。商標は無期限に更新可能
- 経済スパイ法は、米国企業から営業秘密を盗んだ者に罰金と懲役刑を科す米国の法律
- パブリックドメインは、目的を問わず誰でも無制限に使用できるライセンス
- デジタルミレニアム著作権法 (DMCA) は、デジタル化された著作物に関する米国の法律
    - デジタルデータの複製を防止する技術を回避するソフトウェアなどの開発・頒布を禁止する
    - インターネットサービスプロバイダーは、DMCAの規定の下でセーフハーバー保護を受けることができ、顧客の一時的な違法行為に対する責任を負わない
- 米国特許商標庁 (USPTO) が、特許の登録に関する責任を負う

輸出入管理

- ワッセナー・アレンジメント（ワッセナー協定）とは、通常兵器や、軍事転用が可能な汎用品（デュアルユース品）・技術が特定の国やテロリストに渡るのを防ぐため、国際社会が協調して輸出管理を行うための多国間枠組み（国際輸出管理レジーム）です。 1996年に発足し、日本を含む世界42カ国が参加しています。オランダの「ワッセナー」という街で設立交渉が行われたことが名前の由来です。
- 国家間で輸出入される技術が、国家間の戦力バランスを変えないようにするために条約が結ばれる 特に暗号技術が規制対象になる場合がある

1-5. 調査のタイプの要件を理解する

- 調査には5つのタイプがある
    - 管理（内部）
        - 組織内のルールやガバナンスが機能しているかを確かめる。
    - 民事
        - 他者との契約や、損害賠償などの私人間・企業間のトラブルリスクを調べる。
    - 規制
        - 国や政府が定める法律・公的な規制（行政法）に違反していないか調べる。
    - 犯罪
        - 警察や検察の捜査対象となるような重大な違法行為（刑法違反など）の有無を調べる。
    - 業界標準
        - 法律ではないが、その業界でビジネスを行うために必須となる共通ルールを満たしているか調べる。

1-6. セキュリティポリシー、スタンダード、プロシージャ、およびガイドラインを策定、文書化し、実装する

プライバシーフレームワーク

- プライバシー管理フレームワーク（PMF）
    - PMFは、米国公認会計士教会（AICPA）によって2009年にプライバシー原則（GAPP)の改訂版として作成された
    - 一般データ保護規則（GDPR）やAICPAnoトラストサービス基準（TSC）の更新なそ、データプライバシーに関する法律と基準が組み込まれた

サイバーセキュリティフレームワーク

- ISO 27000 と ISO 27001 【世界標準のセキュリティ体制】
    - ISO 27000：セキュリティの「専門用語」を正しく理解するための共通の辞書です。
    - ISO 27001：企業が情報を安全に管理する仕組み（ISMS）を作るための世界共通の教科書です。これに沿って体制を作り、厳しい審査に合格すると「認証」がもらえます。取引先に対して「うちは国際基準を満たした安全な会社です」と証明するのに最も使われます。
- NIST RMF と NIST CSF 【米国政府発の管理ツール】
    - RMF（リスク管理フレームワーク）：システムを導入する際のリスクを「ガバナンス、特定、防御、検知、対応、復旧、監視」のステップで管理する厳格なプロセスです。
    - CSF（サイバーセキュリティフレームワーク）：経営層でも直感的に理解しやすいよう、セキュリティのやるべきことを「防御する」「検知する」「復旧する」といったシンプルな5〜6つの機能に分類したガイドラインです。
    - 💡 【重要】CSF と HITRUST（ハイトラスト）のつながり：CSFは経営目線の「ガイドライン」であるため、具体的な細かいチェック項目までは用意されていません。そこで、特に医療や規制の厳しい業界でよく使われるのが「HITRUST CSF」です。
    - HITRUSTは、NIST CSFの考え方をベースにしつつ、ISO 27001や各種法律（HIPAAやGDPRなど）を丸ごと飲み込んで、「具体的に何を何個クリアすればいいか」をまとめた超具体的な最強のセキュリティ基準（コントロール・ライブラリ）です。
- STAR 【クラウド専用のセキュリティ証明】
    - STAR：クラウドサービス（SaaSやPaaSなど）に特化したセキュリティの格付け・認証制度です。
    - 💡 【重要】STAR と CSA（クラウド・セキュリティ・アライアンス）のつながり：STARという制度自体を運営しているグローバルな非営利団体が「CSA」です。CSAは、クラウド特有のリスク（他人のデータと混ざらないか、クラウド事業者が夜逃げしないか等）を守るための基準を作っています。実務では、ベースとなる「ISO 27001」の認証の上に、CSAのクラウド専用ルールをトッピングする形で審査を受けることで、「STAR認証（レベル2）」を取得できます。クラウド大手のAWSやGoogle Cloudなどもこれを取得しています。

リスクフレームワーク

- ISO 31000 【全社リスク管理の「世界共通の基礎」】
    - 対象： 企業が抱えるすべてのリスク（経営危機、自然災害、円高、サイバー攻撃など何でも）。
    - 役割： あらゆるリスク管理の基本となるプロセス（特定 → 分析 → 評価 → 対策）を定めた国際ガイドラインです。
    - つながり： 前回登場した「ISO 27001」は、このISO 31000の考え方を「情報セキュリティ」に特化させたものです。そのため、ISOの規格で社内ルールを統一したい企業の土台となります。
- COSO（コソ） 【経営層・CFO向けの「ガバナンスの最高峰」】
    - 対象： 経営戦略・ビジネス目標に直結する「最上位」のリスク。
    - 役割： 主に大企業の取締役会やCEO・CFOが、「経営戦略の中にどうリスク管理を組み込むか」を考えるための枠組み（ERM：全社的リスクマネジメント）です。

    - つながり： 会計監査や内部統制（J-SOX法など）の文脈で世界的に最も重視されています。ITやセキュリティよりも「組織のガバナンスと文化、不正防止」といった、経営目線の言葉で書かれているのが特徴です。
- ISACA RISK IT 【ITに特化した「ビジネス目線のリスク管理」】
    - 対象： IT（情報技術）の利用によって生じるビジネス上のリスク（システムの停止、プロジェクトの失敗など）。
    - 役割： 国際団体ISACAが策定した、「ITリスクをビジネスの言葉（経営陣が理解できる言葉）に翻訳して管理する」ためのフレームワークです。
    - つながり： ITガバナンスの有名な基準である「COBIT」と完全に連動しています。ただ条件を並べるだけでなく、「コストと効果のバランス」や「オープンなコミュニケーション」を重視し、現場と経営陣の架け橋になります。
- NIST SP 800-37 【米国政府お墨付きの「超具体的システム認証手順」】
    - 対象： 個別の情報システムや組織が抱えるIT・プライバシーリスク。
    - 役割： 前回紹介した「RMF（リスク管理フレームワーク）」の取扱説明書（本編）にあたる公文書です。システムを安全に稼働させて良いかトップが承認するまでの「7つの手順（準備、分類、選択、実施、評価、承認、監視）」が非常に具体的に書かれています。
    - つながり： 主に米国の政府機関や軍、またはそこにシステムを納める企業（サプライチェーン）が、厳格なセキュリティ評価を行うために使用する実務的なツールです。

セキュリティコントロールフレームワーク

- ギャップ分析（Gap Analysis）とは、組織やビジネスにおける「現状（As-Is）」と「理想・目標（To-Be）」のあいだにある「格差（ギャップ）」を洗い出し、それを埋めるための課題を特定する手法です。これまで確認してきた情報セキュリティ、リスク管理、プライバシー保護（ISO 27001、NIST CSF、AICPA PMFなど）の各種フレームワークを組織に導入する際、最初に行う最も重要で実務的なステップとなります。

1-7. 事業継続（BC）要件を特定、分析、評価、優先づけし、実装する

適切なBC標準の選択

- ISO 22301:2019 【BCP/BCMの「世界共通の教科書（認証規格）」】
    - 役割: 組織がBCM（事業継続マネジメントシステム）を構築・運用するための「具体的な要求事項（ルール）」を定めた最重要規格です。
    - 特徴: 厳しい第三者審査に合格すると認証を取得できます。取引先や社会に対して「災害時でもサプライチェーンを止めない体制がある」と客観的に証明するのに最も使われます。
- ISO 22300:2018 【セキュリティ・レジリエンスの「用語集」】
    - 役割: ISO 22301やその他の関連規格で使われる「事業継続」「災害復旧（DR）」「回復力（レジリエンス）」といった専門用語の定義をまとめた辞書です。
    - 特徴: 組織内や世界中の専門家との間で、言葉の定義に誤解やズレが起きないようにするために参照されます。
- ISO 22313:2013 【ISO 22301の「わかりやすい解説書」】
    - 役割: 基準が厳格に書かれているISO 22301を、「具体的にどうやって自社に導入・実践すればよいか」を優しく解説した実践ガイドです。

    - 特徴: 「ISO 22301のこの項目は、実務ではこういう書類を作ればOK」といった、具体的なアドバイスやヒントが豊富に書かれています。

- ISO/TS 22315:2015 【BCPの肝となる「影響度分析（BIA）」の専門書】
    - 役割: BCPを策定する上で最も重要なステップである「ビジネス影響度分析（BIA：Business Impact Analysis）」に特化した技術仕様書（ガイドライン）です。
    - 特徴: 「もしこの業務が止まったら、何時間でどれだけの損失が出るか（RTO/RPOの算出）」を、科学的かつ正確に評価・分析するための具体的な手順が示されています。

- NIST SP 800-34 【IT・システムの「災害復旧（DR）」に特化した米政府基準】
    - 役割: 米国NISTが定めた、情報システムやサーバー、ITインフラに特化した事業継続（ITコンティンジェンシプラン）のガイドラインです。
    - 特徴: 上記のISOが「組織や業務全体」を対象としているのに対し、こちらは「ITシステムをどうバックアップし、どう復旧させるか（災害復旧：DR）」に焦点を当てた、技術的で非常に実践的な手順書です。

事業影響度分析（BIA）

- サーベイ：資産オーナー／データコントローラーにインタビューし、組織の資産価値の判断を行う。資産に近い視点だが、固有のバイアスに注意する
- 会計監査：調達／購入ドキュメントを確認して、組織内のすべての資産の価値データを集計。価値は時間と共に変化するためその点に注意。
- 組織が業務のどの側面が信用と長期的な収益を産むだすのに最も価値があるのかを判断するのに役立つ。ただし、顧客は業務の限られた部分しか見れない
- 業界標準／ベストプラクティス

事業継続（BC）要件の特定と優先順位づけ

- 不測の事態が発生しても組織が重要な業務を継続できるようにするために使用されるアクション、プロセス、およびツールは事業継続（BC）と呼ばれる
- クリティカルオペレーション（クリティカルパス、または、ミッションクリティカル機能）

事業継続（BC）と災害復旧（DR）の計画要素

- BIAはBCDR計画の全体的な範囲と程度を決定するための基盤を提供
- MAD（Maximum Acceptable Downtime：最大許容停止時間）／MTD
    - 一言で： 会社や業務が「完全に致命傷を負う（倒産・破綻する）までの限界時間」です。
    - 例え： 人間でいう「息を止めていられる限界の時間（これを超えると死んでしまう）」です。すべての復旧目標（RTOなど）は、このMADより前に設定しなければなりません。
    - Maximum Tolerable Downtime（最大許容中断時間）ともいう
- RTO（Recovery Time Objective：目標復旧時間）
    - 一言で： ITシステムやサーバーなどの「インフラの修理・起動を完了させる目標時間」です。
    - 注意： RTOの時点では、システムは動きますが、まだ現場の業務はスタートできていません（壊れたパソコンが起動しただけの状態）。
- WRT（Work Recovery Time：作業復旧時間）
    - 一言で： システムが直った後、「溜まった手書き伝票の入力やデータの不整合チェックを行い、通常の業務に戻るまでの作業時間」です。

    - 重要：【RTO ＋ WRT】が、実際に現場が完全に業務を再開できるまでのトータルの時間になります。これがMAD（限界点）を超えないように計画します。
- RPO（Recovery Point Objective：目標復旧時点）
    - 一言で：過去に遡って、「どれくらい前のデータまで元通りに復元するか」というデータの若さの目標です。
    - 例え：「毎日夜24時にバックアップを取る」運用なら、夕方にシステムが壊れた場合、最大で「1営業日分（16時間分）のデータ」が消えます。この「これだけのデータ消失ならビジネス上耐えられる」という目標値がRPOです。

コンプライアンス要件

- 全ての組織は、ある種の外部からの義務（mandate）の下で運営されている
- コンプライアンスとは、ソースに関係なく、義務を遵守すること
- 米国では、HIPPAは、組織が適切なデータバックアップ計画と緊急運用モード計画の両方を持つことを義務付けている
- Australian Central Securities Depository（Austraclear）は全ての参加者に対してBCPを整備することを要求している

外部依存関係

- クリティカルパスを特定したのち、すべての依存関係を把握する必要がある
- サプライチェーンリソースや依存する資産が含まれる

1-8. 人員のセキュリティポリシーとプロシージャの策定および実行

候補者のスクリーニングと採用

- 詳細で信頼性の高い職務記述書
- 候補者のリファレンスをチェックする
- 職歴の確認
- バックグラウンドチェックの実施
- 財務プロファイルの評価

雇用契約とポリシー

- 従業員とスタッフの信頼性とセキュリティ強化のツール
    - 従業員ハンドブック
    - 雇用契約
    - 秘密保持契約（NDA）

コンプライアンスポリシー要件 - 利用規定

- 組織は全ての人員に対して、利用規定（AUP）を使用する必要がある
    - ユーザー（従業員や顧客）に対して「システムやネットワークを正しく安全に使うためのルール」を定めた文書
        - データアクセス
        - システムアクセス
        - データ開示
        - パスワード

        - データ保持
        - インターネット利用
        - 会社のデバイスの使用状況

プライバシーポリシーの要件

- 個人を特定できる情報（PII）や医療業界における保護された医療情報（PHI）にアクセスできる場合、そういった機微データを取り扱うことによる法的影響を認識していることを文章化することが不可欠
    - EU：GDPR
    - カナダ：PersonalInformationProtectionandElectronicDocuments Act（PIPEDA）
    - HIPPA
    - グラム・リーチ・ブライリー法（GLBA）
        - 1999年に米国で制定された連邦法で、別名「金融サービス近代化法

秘密保持契約（NDA）

- NDAは、文脈や業界によって以下のように呼ばれることがありますが、本質的な目的（秘密を守る）は同じです。
    - CA（Confidentiality Agreement）
        - 意味： 秘密保持契約。NDAと完全に同じ意味で、英語圏や法務の現場ではNDAと同等、あるいはそれ以上に好んで使われる名称です。
    - CDA（Confidential Disclosure Agreement）
        - 意味： 機密開示契約。主に製薬・ライフサイエンス業界や研究開発の現場で好まれる表現です。
    - PIA（Proprietary Information Agreement）
        - 意味： 専有情報契約。主にIT・ハイテク業界や製造業において、自社特有の技術やソースコード（IP）などの「財産的価値のある情報」を守るニュアンスを強めた表現です。
    - SA（Secrecy Agreement）
        - 意味： 機密保持契約。防衛産業や、より公的な機関との取引などで使われることがある呼称です。
- 契約形態
    - 片務（へんむ / One-way）
        - 意味： 「一方向のみ」情報を開示する形態です（例：発注側が受注側にのみ秘密情報を渡す）。情報を出す側だけが厳しく守られる内容になります。
    - 双務（そうむ / Mutual）
        - 意味： 「お互いに」情報を開示し合う形態です（例：共同開発やM&Aの検討段階）。双方に同等の秘密保持義務が課されるため、公平で契約交渉がスムーズに進みやすい特徴があります。
    - 多社間（Multiparty）
        - 意味： コンソーシアムや3社以上の共同プロジェクトで結ばれる、「3社以上」が同時に署名するNDAです。情報の流出元や責任の所在が複雑になるため、より緻密な設計が必要です。
- 特殊な条項
    - 競業避止（きょうぎょうひし / Non-compete）
        - 意味： 開示された秘密情報（技術やアイデア）を使って、「ライバルとなる類似ビジネスを勝手に立ち上げてはならない」と制限する条項です。
        - 実務での注意： 開発会社などに情報開示する際、IP（知的財産）を盗まれて真似されるのを防ぐために強力な壁となります。ただし、制限が厳しすぎると独占禁止法や営業の自由を侵害するため、期間や範囲を限定するのが一般的です。

ベンダー、コンサルタント、業者との契約とコントロール

- 契約上の保護：金銭的な条項や責任の明確化
- NDAとNCA
- 明確な制限付きアカウント
- エスコート要件
- 区別した識別：従業員用のバッチと違うなど

1-9. リスクマネジメントの概念を理解し、適用する

- NIST サイバーセキュリティフレームワーク（NIST CSF：Cybersecurity Framework）とは、米国国立標準技術研究所（NIST）が策定した、組織のサイバーセキュリティリスクを評価・改善するための世界的なガイドライン（共通言語）です。
- 最新のCSF 2.0では、セキュリティ活動を6つの基本機能に分類しています。従来の「5機能」に対し、経営陣の責任や戦略を明確にする「GOVERN（統治）」が中心に据えられたのが最大の特徴です。（CISSPの教科書上は5つ）
    - ① GOVERN（統治） ★新設 セキュリティの方針、責任体制（ガバナンス）、リスク受容の基準を決定する。サプライチェーン（委託先）のリスク管理もここに含まれる。
    - ② IDENTIFY（特定） 自社が持つ資産（端末、サーバー、SaaS、データ）や業務の流れを棚卸しし、どのようなリスクがあるかを把握する。
    - ③ PROTECT（防御） 攻撃による被害を未然に防ぐ、または抑えるための壁を作る（多要素認証、アクセス制御、データ暗号化、従業員教育、バックアップなど）。
    - ④ DETECT（検知） 不正アクセスやマルウェア感染などの異常やセキュリティイベントを早期に発見・監視する（ログ監視、アラート通知など）。
    - ⑤ RESPOND（対応） 攻撃を検知した際のインシデント対応（被害の封じ込め、関係各所への連絡・報告、初動手順の実行）を行う。
    - ⑥ RECOVER（復旧） 被害に遭ったシステムや業務を安全に元通りに復元し、今回の原因を分析して今後の再発防止策へつなげる。

フレームワークからワークフローへ：管理されるリスク

- リスクマネジメントは、組織が使用しなければならないすべての時間枠または意思決定期間にまたがる一連の計画-実行-評価-改善サイクル（PDCA）
- リスクマネジメントは、あらゆるアプローチ（トップダウン、ボトムアップ）があり、また、CSFを①から順番に実施する直列なやり方でなくてもよい。すべてのリスクが明確になってから動き出さなくてもよい。

4つの視点：リスクとは何か

- 資産ベース (Asset-Based)
    - 起点： 守るべきデータや機器（資産）
    - 考え方： 「社内にある大事な情報やシステムを洗い出し、それが壊れたり盗まれたりするリスク」を評価する。
- 結果ベース (Results-Based)※プロセスベースと統合
    - 起点： 達成すべきゴールやビジネス上の影響
    - 考え方： 「顧客データを1件も漏らさない」などの最終的な成果・目標を定義し、それを阻害するリスクを評価する。
- プロセスベース (Process-Based)
    - 起点： 日常の業務手順（フロー）
    - 考え方： 「商品の受注から発送まで」といった一連の業務の流れを追いかけ、その途中に潜むリスクを評価する。

- 脆弱性ベース (Vulnerability-Based)
    - 起点： 自社が抱える「弱点（穴）」
    - 考え方： システムのバグや設定ミス、ルールの不備など、内側にある欠陥を洗い出してリスクを評価する。
- 脅威ベース (Threat-Based)
    - 起点： 外や中から襲ってくる「敵や災害」
    - 考え方： ハッカー、内部不正、大地震など、組織に害を与える具体的なシナリオを想定してリスクを評価する。

最前線の実施事項

- 脅威インテリジェンスアクティビティ（Threat Intelligence Activities）
    - 一言で： 「敵（ハッカーなど）の最新情報を集めて先回りする活動」です。
    - やること： 世の中で今どんなサイバー攻撃が流行しているか、自社が狙われていないかを外部のデータから常にリサーチし、攻撃される前に防御を固めるために使います。
- 継続的なプロセスの成熟と改善（Continuous Process Maturity and Improvement）
    - 一言で： 「セキュリティの仕組みを形骸化させず、どんどん強くしていく活動」です。
    - やること： 一度作ったルールやシステムを放置せず、定期的にテスト（ギャップ分析など）を行い、時代の変化に合わせて「より高いレベル（成熟度）」へブラッシュアップし続けます。
- 資産と資産評価（Assets and Asset Valuation）
    - 一言で： 「会社の大事なものリストを作り、それぞれの価値（値段）を決める活動」です。
    - やること： 社内にあるデータ、サーバー、知的財産（IP）などを洗い出し、「これが盗まれたら数億円の損害になる」といったビジネス上の重要度（価値）をランク付けします。これにより、予算をどこに集中投下すべきかが明確になります。

リスクに関する定義

- リスクとは：組織に悪影響を与える可能性のあるイベント
- ハザードとは：システム、職場、または環境の前提条件であり、リスクイベントが偶発的に発生すること
- 脆弱性とは：システムまたはコンポーネントに内在する弱点または欠陥のこと
- 脅威とは：目的のために、標的となる組織のシステムの脆弱性を悪用するための行動を取るアクターまたはグループ

リスク対応

- リスクに優先順位をつける
- 低減、回避、移転、受容
    - ISO/IEC 27005:2018での修正
        - 低減（Mitigate）は修正（Modify）
        - 移転（Transfer）は共有（sharing）
- リスク低減
    - リスクイベントまたはその影響の可能性を防止、または軽減するための措置
        - 修復措置：関連するシステムおよびプロセスの修復または変更。リスクイベントの脆弱性を軽減または削除
        - リスクコントロール、またはセキュリティコントロールは、技術的、物理的、および管理的対策の組み合わせで実装
        - ISO/IEC 27005:2018の「修正」は、リスク処理プロセスの一環として変更する
- リスク回避

    - 特定のリスクにされさている組織の活動の一部または全部の運営を停止する
    - 低減リスクと残存リスクを考慮
- リスク移転
    - リスクが現実のものとなったことで生じた損害の経済的影響を他の当事者に負担させ、その見返りとして、その影響の全体コストの一部を支払う行為（保険など）
    - ISO 27005では、「リスク共有」と改名
- リスク受容
    - 回避の逆で、組織がそれ以上のアクションを起こさずリスクを受容する

リスクエクスポージャー

- エクスポージャーウィンドウ（Exposure Window）
    - 一言で：「システムが危険にさらされている期間」です。
    - 中身： システムに「弱点（バグ）」が見つかってから、対策（修正パッチなど）が適用されて完全に穴が塞がるまでの無防備な時間帯を指します。この期間が長いほど、ハッカーに攻撃される確率が上がります。
- エクスポージャー係数（EF：Exposure Factor）
    - 一言で：「トラブルが起きたとき、その資産の価値が何％失われるかという割合」です。
    - 中身： 0%〜100%の数値（または0.0〜1.0）で表します。例えば「1億円のサーバーがサイバー攻撃を受けた場合、データの復旧費用や被害で価値の30%（0.3）が失われる」と予測するなら、EFは30%（0.3）になります。
- エクスポージャー推定（Exposure Estimation / リスク評価）
    - 一言で：「資産価値に上記の係数や期間を掛け合わせて、最終的な被害総額を計算（推定）する作業」です。
    - 中身：「資産の値段 × エクスポージャー係数（被害の割合）」などの計算式を使い、「結局、このリスクが起きたら会社はいくら損をするのか？」を具体的な金額で算出します。

定性的評価と定量的評価

- 定量的評価（Quantitative Assessment）
    - 一言で： リスクを「1回あたり3,000万円の損失」「年間発生確率5%」のように、具体的な「数値や金額」で表す評価方法です。
    - メリット：「対策にいくら投資すべきか」を経営陣がお金（コストパフォーマンス）の目線で判断しやすいのが最大の強みです。反面、データの収集や計算に手間がかかります。
- 定性的評価（Qualitative Assessment）
    - 一言で： リスクを「高（High）」「中（Medium）」「低（Low）」のように、「深刻度や優先度のランク（言葉）」で表す評価方法です。
    - メリット： 専門的なデータがなくても、アンケートやディスカッションなどで短時間かつ低コストでざっくりと評価できるため、実務で最も広く使われています。ただし、評価する人の主観に左右されやすい弱点があります。
    - 新規性：活動、コンテキスト、市場、または組織事態が新しく測定に使用するための実績がない
    - 独自性：組織が業界や市場に対して比較できない
    - 定量的推定に充てるリソースがない
    - データ収集のための方法がない
- FAIR手法（Factor Analysis of Information Risk：情報リスクの要因分析）
    - 一言で： 曖昧になりがちなIT・セキュリティのリスクを、科学的に正しく「定量的（金額）」に計算するための世界標準のフレームワークです。

- 特徴： 前回説明した「リスクエクスポージャー（損失額）」を計算する際、当てずっぽうで数字を決めるのではなく、「攻撃の頻度」や「資産の脆弱性」「被害の割合」といった細かな要因に分解（フレームワーク化）して、論理的な金額を導き出します。国際標準の「Open FAIR」として認定されており、NIST CSFなどとも組み合わせて使われます。

シュミレーションとリスク評価

- ペネトレーションテスト：ペネトレーションテスト（Penetration Testing / 侵入実験）とは、専門のセキュリティエンジニア（ホワイトハッカー）が、実際のサイバー攻撃者と同じ手法を使って自社のシステムやネットワークに擬似的に侵入し、どこまで突破できるかを検証する実践的なテスト

リスク評価とリスク処理の決定

- AV（Asset Value：資産価値）
  - 一言で： 守るべきデータやシステムの「元の値段・価値」です。
- SLE（Single Loss Expectancy：単一損失予想額）
  - 一言で： そのトラブルが「1回」起きたときに失われる金額です。

> 計算： AV（資産価値） × EF（エクスポージャー係数：被害の割合）

- ARO（Annualized Rate of Occurrence：年間発生率）
  - 一言で： そのトラブルが「1年間に何回くらい起きそうか」という頻度です。
  - 表し方： 年に2回なら 2、2年に1回（半年に0.5回）なら 0.5 と表します。
- ALE（Annualized Loss Expectancy：年間損失予想額）
  - 一言で： そのリスクを放置した場合、「1年間でトータルいくら損をするか」という最終的な被害見積もりです。

> 計算： SLE（1回あたりの損害） × ARO（年間の回数）

「ネットショップのサーバーダウン」を使った具体例

- あなたの会社が運営している、ネットショップのサーバー（システム）を例に計算してみましょう。
  - 1. AV（資産価値）を決める
    - このネットショップのシステム全体の価値や、止まった場合の売上規模から、システム全体の価値を 1,000万円 と見積もります。

      > AV ＝ 1,000万円

  - 2. SLE（1回あたりの損害）を計算する
    - もしサイバー攻撃（ランサムウェアなど）を受けてシステムが一時的にダウンした場合、データの復旧費用やその間の売上減少で、システム価値の20%（＝エクスポージャー係数）が失われると推定します。
      - 1,000万円 × 20%（0.2） ＝ 200万円

      > SLE ＝ 200万円 （1回壊れたら200万円の損）

  - 3. ARO（年間の回数）を見積もる
    - 過去のデータや最新の脅威インテリジェンスから、このレベルの攻撃を受ける確率は「5年に1回」だと予測します。
      - 1 ÷ 5年 ＝ 0.2

> ARO ＝ 0.2

- 4. ALE（1年間のトータル損害）を弾き出す
  - 最後に、「1回あたりの損害」と「年間の回数」を掛け合わせます。
    - 200万円（SLE） × 0.2（ARO） ＝ 40万円

> ALE ＝ 40万円

適用可能なコントロールのタイプ

- 技術／論理コントロール
  - FW, ACLなど
- 物理コントロール
  - 壁、フェンスなど
- 管理コントロール
  - ポリシーとプロシージャなど

セキュリティコントロールのカテゴリー

- セキュリティコントロール（対策）の7つのカテゴリーを、「何をするための対策か（目的）」に絞って一言でシンプルに整理しました。
- 指示（Directive）
  - 目的： 正しい行動を「命令・案内」する。
  - 例： セキュリティ基本方針、社内規定（AUP）、標識。
- 抑止（Deterrent）
  - 目的： 攻撃者や違反者に「やめておこう」と思わせる（心理的プレッシャー）。
  - 例： 「防犯カメラ作動中」の看板、ログイン時の警告画面。
- 防止（Preventive）
  - 目的： 攻撃や違反を「物理的・技術的にブロック」して防ぐ。
  - 例： ファイアウォール、多要素認証（MFA）、部屋の施錠。
- 補償（Compensating）
  - 目的： 本来の対策ができないときに「別の方法で穴埋め（代替）」する。
  - 例： 暗号化できない古いシステムを、隔離された専用ネットワークに入れる。
- 検知（Detective）
  - 目的： 起きてしまった攻撃や異常を「素早く見つける」。
  - 例： ログ監視ツール、侵入検知システム（IDS）、防犯カメラの録画。
- 是正（Corrective）
  - 目的： トラブル発生直後に「被害の拡大を止め、原因を直す」。
  - 例： ウイルスに感染したパソコンのネットワーク遮断、バグの修正パッチ適用。
- 復旧（Recovery）
  - 目的： システムや業務を「元の正常な状態に戻す」。
  - 例： バックアップからのデータ復元、BCP（事業継続計画）の発動。
- この7つのカテゴリーは、前回のALE（年間損失予想額）などの計算を踏まえ、どこに予算を投資すべきかを決める際の分類に使われます。もし、自社のセキュリティ対策がこれらのバランス良く配置されているかチェックする「コントロールの棚卸し」について興味があれば教えてください。
- 多層防御：多層防御（Defense in Depth）とは、セキュリティ対策を1つの壁（防壁）だけに頼るのではなく、「複数の異なる対策（レイヤー）を重ね合わせることで、どこかが突破されても全体を守り切る」というセキュリティの基本思想

コントロールの選択

- NIST RMFのプロセスと選択
  - 意味： システムの計画から運用開始、廃棄にいたるまでのライフサイクル（7つのステップ）の中で、「そのシステムに最適な対策を論理的に選ぶ」ステップのことです。
  - やり方： システムを導入する際、最初に対象データの重要度（機密性・完全性・可用性）を「高・中・低」に分類します。その格付けに合わせて、必要な対策をカタログ（NIST SP 800-53など）から選び出し、組織のトップが承認するプロセスを踏みます。
- ベースラインコントロール（Baseline Controls）
  - 意味： ゼロから対策を考えるのではなく、「法律や基準によってあらかじめ用意された、最低限クリアすべき標準の対策セット（標準パッケージ）」のことです。
  - 役割： 例えば、システムの重要度が「中（Medium）」と分類された場合、自動的に「中レベル用のベースライン（例：パスワードは12文字以上、ログは1年保存など）」が割り当てられます。これを土台（スタートライン）にすることで、選択の漏れや無駄な検討時間をなくします。
- 組織生成コントロール（Organization-Generated Controls）
  - 意味： 上記の「標準パッケージ（ベースライン）」だけではカバーできない、「自社特有のビジネス環境やリスクに合わせて、組織が独自に作り出す追加の対策」のことです。
  - 役割： 標準ルール（ベースライン）を自社向けにカスタマイズ・補強する役割を持ちます。例えば、「自社は生成AIを高度に活用する業務プロセスがあるため、ベースラインに加えて『AIへのデータ入力制限（AI AUP）』を独自に追加する」といったケースがこれにあたります。

コントロールの評価

- セキュリティ評価（米政府基準）の文脈：Security Control Assessment（セキュリティ管理策評価）
- 「NIST RMF（リスク管理フレームワーク）」のプロセス（ステップ5）に登場する専門用語です。
  - やること：「コントロールの選択」で決めたセキュリティ対策（ベースラインなど）が、「システムに正しく導入され、計画通りに機能しているか」を専門の評価者がテスト・確認するプロセスのことです。この評価結果（SCAレポート）を基に、組織のトップがシステムの運用を開始して良いか（認証授与：SP 800-37）を判断します。

監視と測定

報告

継続的改善

リスクフレームワーク

1-10. 脅威モデリングの概念と方法論を理解し、適用する

- 脅威モデリング（Threat Modeling）とワークフロー図（データフロー図：DFDなど）は、システムやアプリの開発において「設計図を見て、どこが襲われそうか（リスク）を先回りして見つける」という密接な関係（手段と目的の関係）にあります。
- 先ほどのリスク管理のアプローチでいうと、主に「脅威ベース（敵の目線）」と「プロセスベース（業務の流れ）」を掛け合わせた非常に実践的なセキュリティ設計の手法です。

STRIDE

- STRIDE（ストライド）とは、マイクロソフト社が開発した、システム設計の段階で「ハッカーが突いてくる代表的な6つの脅威」を洗い出すための世界標準のフレームワークです。 先ほど説明した「ワークフロー図」を見ながら、各ステップにこの6つの穴がないかをチェック（脅威モデリング）します。
- 1. S：Spoofing（なりすまし）
  - 意味： 他人のIDやパスワード、証明書などを盗み、「偽物の人間やシステムが、本物のふりをして侵入する」ことです。
  - 対策： 多要素認証（MFA）の導入、デジタル証明書による厳格な本人確認（認証）。
- 2. T：Tampering（データの改ざん）
  - 意味： 通信中のデータや、データベースに保存されている「データを、ハッカーが勝手に書き換えてしまう」ことです（例：振込金額の書き換え）。
  - 対策： データの暗号化、ハッシュ値による改ざん検知、アクセス制限（完全性の確保）。
- 3. R：Repudiation（否認）
  - 意味： トラブルや不正操作が起きたときに、犯人から「私はそんなことやっていません」と証拠隠滅や言い逃れ（否認）をされてしまうことです。
  - 対策： 改ざんできない形での「操作ログ」の保存、タイムスタンプの記録（否認防止）。
- 4. I：Information Disclosure（情報の漏洩）
  - 意味： サーバー内の機密データや顧客情報が、「権限のない外部の人間に盗まれて見られてしまう」ことです（機密性の侵害）。
  - 対策： 保存データ・通信データの暗号化、厳格なアクセス権の設定。
- 5. D：Denial of Service（サービス拒否 / DoS・DDoS攻撃）
  - 意味： 大量のゴミデータを送りつけるなどして、「サーバーやシステムを過負荷でダウンさせ、一般ユーザーが使えない状態にする」ことです（可用性の侵害）。
  - 対策： ファイアウォールでの一括遮断、CDN（負荷分散システム）の導入、BCP（事業継続計画）の準備。
- 6. E：Elevation of Privilege（権限の昇格）
  - 意味： 一般ユーザーとしてログインしたハッカーが、システムのバグ（脆弱性）を悪用して、「システムを何でも支配できる『管理者（ルート権限）』に乗っ取ってしまう」ことです。
  - 対策： ペネトレーションテストによるバグの修正、最小限の権限だけをユーザーに与えるルール（最小権限の原則）。

そのほか脅威モデル

- DREAD（ドレッド） 【特定した脅威の「格付け・スコアリング」】
  - 一言で： STRIDEなどで見つけた脅威に対して、「どれくらい危険か」を数値化（1〜10点）して優先順位を決めるための仕組みです。
  - 評価する5つの要素（頭文字）：
    1. Damage（損害）：どれほど甚大な被害が出るか
    2. Reproducibility（再現性）：攻撃をもう一度成功させるのは簡単か
    3. Exploitability（攻撃容易性）：高度な技術がなくても攻撃できるか
    4. Affected users（影響ユーザー）：どれくらい多くのユーザーに被害が及ぶか
    5. Discoverability（発見可能性）：ハッカーから見て、その弱点（穴）は見つけやすいか
- PASTA（パスタ） 【ビジネス利益を守る「攻撃者目線の7ステップ」】
  - 一言で： 「ハッカーの具体的な攻撃シミュレーション」と「会社のビジネス目標」を合体させた、超実践的な7段階のリスク評価プロセスです。
  - 特徴： 単に技術的なバグを探すだけでなく、「そもそもこのアプリが攻められたら、会社の売上や信用にどう響くか」というビジネスインパクトの定義からスタートします。その後、アタックツリー（攻撃ルートの木構造図）などを描いて、リアルな攻撃シナリオを検証します。

- ATASM（アタズム） 【クラウドやアーキテクチャの「攻撃面」に着目】
  - 一言で： 「構造（Architecture）」「脅威（Threat）」「攻撃面（Attack Surface）」「緩和策（Mitigations）」の頭文字を取った、クラウド（CCSP）や大規模システム向けのフレームワークです。
  - 特徴： システムの「設計図（構造）」を分解し、ハッカーの侵入口となり得る「攻撃面（アタックサーフェス）」をすべて洗い出すことに特化しています。その上で、既存の防御壁（緩和策）が効いているかを検証します。
- OCTAVE（オクターブ） 【組織の「重要資産」から考えるボトムアップ型】
  - 一言で： カーネギーメロン大学が開発した、「技術」ではなく「組織と資産」を中心に据えた経営・ガバナンス寄りのリスク評価手法です。
  - 特徴： ハッカーの攻撃手法を追う前に、まず「我が社にとって本当に守るべき情報やシステム（資産）は何か」を徹底的に洗い出します。現場のスタッフを巻き込みながら、組織のポリシーや運用の弱点を3つのフェーズでじっくり評価していくのが特徴です。
- LINDDUNの6つのプライバシー脅威
  1. L：Linkability（リンク可能性・紐付け）
     - 意味： 別々のデータ（例：購入履歴と位置情報）がハッカーや第三者に紐付けられ、「これが誰のデータか」を特定されてしまう脅威です。
  2. I：Identifiability（識別可能性・特定）
     - 意味： システム内の匿名データや暗号化データから、ユーザーの氏名や住所などの個人が直接特定されてしまう脅威です。
  3. N：Non-repudiation（否認不可・追跡）
     - 意味： ユーザーがシステム上で「いつ、何をしたか（例：どのWebサイトを見たか）」を第三者に完全に追跡・証明されてしまい、プライバシーが筒抜けになる脅威です。
  4. D：Detectability（検出可能性・推測）
     - 意味： データそのものは見えなくても、データの「有無」や「通信のタイミング」などから、ユーザーの重要な秘密（例：特定の病気の治療を受けていることなど）を推測されてしまう脅威です。
  5. D：Disclosure of information（情報の開示・漏洩）
     - 意味： 適切な保護（暗号化など）がされておらず、個人情報が権限のない外部の人間に見られてしまう脅威です（STRIDEの「I」と同じ）。
  6. Un：Unawareness for the user（ユーザーの不認知）
     - 意味： 自分の個人情報が「いつ、どのように、何の目的で使われているか」をユーザー自身が知らされていない・同意していないという管理上の脅威です。
  7. N：Non-compliance（コンプライアンス不遵守）
     - 意味： 法律（GDPRや個人情報保護法）や、社内のプライバシーポリシー（AICPA PMFなど）に違反した形でデータを取り扱ってしまう脅威です。

1-11. サプライチェーンリスクマネジメント（SCRM）概念を適用する

ハードウェア、ソフトウェア、サービスに関するリスク

- ハードウェア：組み立てラインで使用されており、製造がそれらに依存しているため、ハードウェアリスクをもたらす
- ソフトウェア：ゼロデイエクスプロイト（Zero-day Exploit）とは、ソフトウェアやシステムに発見された「セキュリティの穴（脆弱性）」が、開発元が修正パッチを配布する前（対策が0日目）に悪用されて行われるサイバー攻撃、またはその攻撃用プログラムのことです。

サードパーティの評価とモニタリング

- ISO認定の監査（ISO/IEC 27001監査など）
  - 対象： 企業全体の情報セキュリティ体制（ISMS）
  - 役割： 国際規格（ISO）が定めたルール通りに、会社が安全に情報を管理できているかを第三者の審査機関がチェックする監査です。合格すると世界共通の「認証」がもらえ、最も一般的な信頼の証明になります。
- Cloud Security Alliance（CSA）STAR評価
  - 対象： クラウドサービス（SaaS/PaaS/IaaS）のセキュリティ
  - 役割： 国際団体「CSA」が運営する、クラウド専用のセキュリティ格付け制度（STAR）です。前述のISO 27001の上に、クラウド特有の安全基準を上乗せして評価し、AWSやGoogle Cloudなどの大手も信頼の証として取得しています。
- 米国公認会計士協会（AICPA）
  - 対象： 企業の内部統制やプライバシー体制の基準策定
  - 役割： グローバルで企業の信頼性を証明する「SOC 2報告書」の監査基準や、前に登場した個人情報保護の設計図である「AICPA PMF」を開発・運営している、米国の歴史ある公認会計士の団体です。

シリコンレベルの信頼性（Silicon Root of Trust）

- サーバーやPC、IoT機器などのデバイスが起動する際、「ハードウェア（半導体チップ）の段階から一切改ざんされていないこと」を完全に保証するセキュリティの仕組み（根拠）です。

Physically Unclonable Function

- （PUF：物理複製困難関数）とは、半導体チップの製造時にどうしても生じてしまう微細な「個体差（ばらつき）」を利用して、チップごとに絶対に複製できない固有の暗号鍵やIDを自動生成する技術です。

ソフトウェア部品表

- ソフトウェア部品表（SBOM：Software Bill of Materials）とは、自動車の部品リストや食品の原材料表示のように、ソフトウェアに含まれるすべてのオープンソース（OSS）やサードパーティ製のライブラリなどの「コンポーネント（部品）一覧」を書き出したデータシートのことです。

1-12. セキュリティアウェアネス、教育、トレーニングプログラムを確立し、維持する

教育、トレーニング、アウェアネス

- アウェアネス（Awareness：意識向上）
  - 対象： 役員、正社員、派遣社員、外部委託先を含む「すべての構成員」
  - 目的： セキュリティを他人事ではなく「自分事」として捉え、日頃の行動規範（AUPなど）をリマインドすること。
  - やること： ポスターの掲示、ログイン時の警告画面、定期的なフィッシングメール訓練（模擬攻撃）。「あ、これは怪しいな」と直感的に気づく力を養います。
- トレーニング（Training：実務訓練）
  - 対象： 開発者、インフラ担当者、セキュリティ運用チームなどの「特定の専門職」
  - 目的： 実務に必要な「具体的な技術、手順、スキル」を習得・実践できるようにすること。
  - やること： 安全なコードの書き方（セキュアコーディング）、脅威モデリングの演習、ペネトレーションテストの結果を踏まえたバグ修正、BCP/BIAに基づく復旧訓練。

- 教育（Education：理論学習）
  - 対象： セキュリティ責任者（CISO）、リスク管理者、将来の幹部候補
  - 目的： 単なる手順の暗記ではなく、「なぜその対策が必要なのか」という理論・背景を理解し、経営判断やリスク評価ができるようになること。
  - やること： 各種フレームワーク（NIST CSF、ISO 27001、COSOなど）の学習、セキュリティ関連の法規制（GLBAなど）の解釈、リスクの定量的・定性的評価手法の習得。

アウェアネスとトレーニングの提示方法とテクニック

- コンピュータベーストレーニング（CBT）：自分のペースで24時間いつでも受講・中断できる、柔軟で拡張性の高いオンライン学習方法。
- ライブの対面トレーニング：講師と受講者が同じ空間に集まり、直接の対話や個別の質問対応ができる伝統的な講義方法。
- オンライン同期トレーニング：ウェビナーなどの配信システムを使い、遠隔地にいる講師と受講者がリアルタイムで同時に進める学習方法。
- 定期コミュニケーション：ニュースレターや社内メールを通じて、最新の脅威や社内ルールを継続的にリマインドする手法。
- 報酬のメカニズム：不審なメールの報告など、正しい行動をした社員を表彰やインセンティブで評価・推奨する仕組み。
- ゲーミフィケーション：クイズや疑似攻撃のスコア競走など、ゲームの要素を取り入れて受講者のエンゲージメントを高める手法。
- セキュリティチャンピョン：各業務部門から選ばれた代表者が、現場のリーダーとして身近な視点からセキュリティ意識を浸透させる制度。

確認問題バンク

ジュネーブ宣言

- ジュネーブ宣言（Declaration of Geneva）とは、1948年に世界医師会（WMA）が採択した、「医師として人類に尽くすための生涯の誓い（現代版ヒポクラテスの誓い）」です。 ナチス・ドイツによる非人道的な人体実験への反省（ニュルンベルク綱領）から生まれ、医療倫理の根底を支える最重要の宣言となっています。（倫理規約）

📝 GDPRの7つのプライバシー原則

- GDPR（EU一般データ保護規則）の第5条では、個人データを取り扱う際の核心となる7つの基本原則が定められています

1. 適法性・公正性・透明性：法律の根拠に基づき、不正なく、利用目的をわかりやすく明示して処理します。
2. 目的の限定：定めた正当な目的の範囲外でデータを利用してはなりません。
3. データの最小化：目的達成に必要な限度のデータのみを収集します。
4. 正確性：データは正確かつ必要に応じて最新に保ち、誤りは修正・消去します。
5. 保存の制限：必要期間を超えて保持せず、不要時は速やかに消去・匿名化します。
6. 完全性と機密性：漏洩や改ざんを防ぐため、適切なセキュリティ対策で保護します。
7. 説明責任：上記原則の遵守状況を事業者が証明できるようにする責任を負います。

RMF、監査やコントロールアセスメント

- 具体的な管理策の適用
    - SP 800-53（セキュリティとプライバシー管理策のカタログ）:FIPS 200が定める要求事項をクリアするための、具体的な対策（セキュリティコントロール）の膨大なメニュー集です。アクセス制御やインシデント対応など、詳細なセキュリティメニューがここから選択・適用されます。
- リスク管理の手法とライフサイクル
    - SP 800-39（組織全体のリスクマネジメント）:リスク管理を「組織レベル（経営）」「業務プロセスレベル」「情報システムレベル」の3つの階層（ティア）で包括的に捉え、管理・運営するための最上位のフレームワークです。
    - SP 800-37（リスクマネジメントフレームワーク：RMFの適用ガイド）:システムのライフサイクル全体を通じて、リスクをどう評価し、対策を選んで運用承認（認証）を得るかという具体的な「6〜7つのステップ（RMFの手順）」を定めた実務ガイドです。